

Security+ 2.4 · Malicious Code

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.4 — Malicious Code (3:40)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Code do atacante: script customizado (Python/Bash/PowerShell) pra exploit conhecido; macro VBA de Office que baixa malware; shellcode. Defesa: patch, macro security (bloqueia externa), sandboxing, EDR behavioural, code review de script do usuário.

Highlights que a prova cobra

- Macro VBA de documento Office: clássico — executa código ao abrir
- Sandbox: isola código suspeito num ambiente controlado

Dicas de prova & Cenários Típicos

- 'document that runs code when opened' = malicious macro

Cenário clássico de exame: Cenário: 'funcionário abre planilha do email e o macro executa payload' = malicious macro — bloquear macros externas.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.4 — Malicious Code)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **WORM:** Write Once, Read Many: Tecnologia de armazenamento imutável que permite gravar dados uma única vez e impede qualquer modificação ou exclusão durante o período de retenção (essencial para logs e conformidade).

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Qual tipo de malware se espalha automaticamente por redes sem necessidade de arquivo hospedeiro ou interação do usuário?

- A) Worm
- B) Trojan
- C) Spyware
- D) Adware

2. Malware que criptografa seus arquivos e exige pagamento pra devolver é:

- A) Spyware
- B) Ransomware
- C) Rootkit
- D) Worm

3. Cenário corporativo (Malicious Code): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Macro VBA de documento Office: clássico — executa código ao abrir'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Macro VBA de documento Office: clássico — executa código ao abrir...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Malicious Code): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Sandbox: isola código suspeito num ambiente controlado'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Sandbox: isola código suspeito num ambiente controlado...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Malicious Code): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'document that runs code when opened' = malicious macro'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'document that runs code when opened' = malicious macro...

6. Cenário corporativo (Malicious Code): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'funcionário abre planilha do email e o macro executa payload' = malicious macro — bloquear macros externas.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'funcionário abre planilha do email e o macro executa payload' = m...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Malicious Code): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Macro VBA de documento Office: clássico — executa código ao abrir'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Macro VBA de documento Office: clássico — executa código ao abrir...

8. Cenário corporativo (Malicious Code): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Sandbox: isola código suspeito num ambiente controlado'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Sandbox: isola código suspeito num ambiente controlado...

9. Cenário corporativo (Malicious Code): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'document that runs code when opened' = malicious macro'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'document that runs code when opened' = malicious macro...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Malicious Code): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'funcionário abre planilha do email e o macro executa payload' = malicious macro — bloquear macros externas.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'funcionário abre planilha do email e o macro executa payload' = m...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — Worm.

✓ **Por que está certa:** O Worm é um tipo de malware autônomo que se autorreplica e se espalha automaticamente por redes, explorando vulnerabilidades em serviços ou sistemas operacionais, sem necessidade de um arquivo hospedeiro ou de interação do usuário. Diferente de vírus, ele não precisa de um programa portador para se propagar. No CompTIA Security+ (domínio 2.4 - 'Given a scenario, analyze indicators of malicious activity'), o worm é classicamente definido como malware que se espalha sozinho pela rede, consumindo largura de banda e comprometendo sistemas em larga escala. É exatamente o que o enunciado descreve.

✗ **Por que as outras estão erradas:**

- *Trojan*: Um Trojan (cavalo de Troia) é um malware que se disfarça de software legítimo para enganar o usuário e ser executado. Ele depende da interação do usuário para infectar o sistema e não se autorreplica automaticamente pela rede. Portanto, não atende ao critério de 'espalhar-se automaticamente sem interação do usuário'.
- *Spyware*: O Spyware é um software malicioso projetado para coletar informações do usuário sem consentimento, como hábitos de navegação, credenciais e dados pessoais. Ele não se espalha automaticamente por redes; geralmente é instalado por meio de engenharia social ou bundled com outros softwares. Logo, não é a resposta correta.
- *Adware*: O Adware é um software que exibe anúncios indesejados e pode redirecionar o navegador, mas não se autorreplica nem se espalha automaticamente por redes. Sua disseminação depende de instalação pelo usuário ou de outros malwares. Portanto, não atende ao enunciado.

2) B — Ransomware.

✓ **Por que está certa:** A alternativa correta é 'Ransomware'. Ransomware é um tipo de malware que criptografa os arquivos da vítima e exige o pagamento de um resgate (geralmente em criptomoedas) para fornecer a chave de descryptografia. O enunciado descreve exatamente esse comportamento: um malware que criptografa arquivos e exige pagamento para devolvê-los. A CompTIA classifica ransomware como uma ameaça crítica, frequentemente propagada por phishing, exploração de vulnerabilidades ou serviços de área de trabalho remota. Portanto, a opção 'Ransomware' é a definição precisa do ataque descrito.

✗ **Por que as outras estão erradas:**

- *Spyware*: Spyware é um software malicioso projetado para coletar informações do sistema infectado sem o consentimento do usuário, como hábitos de navegação, credenciais, dados bancários, etc. Ele não criptografa arquivos nem exige resgate. Sua principal função é espionar e exfiltrar dados. No cenário, o objetivo é extorquir dinheiro por meio da criptografia de arquivos, o que não é característica do spyware. Portanto, spyware não se aplica.
- *Rootkit*: Rootkit é um conjunto de ferramentas maliciosas que permite ao atacante obter acesso privilegiado (root) e manter persistência no sistema, ocultando sua presença de mecanismos de detecção. Embora possa ser usado em conjunto com ransomware, o rootkit em si não criptografa arquivos nem exige pagamento. Sua finalidade é furtiva, não extorsiva. O enunciado descreve um ataque de extorsão financeira por criptografia, não a instalação de um rootkit. Logo, rootkit não é a resposta correta.
- *Worm*: Worm é um malware autorreplicante que se propaga automaticamente pela rede, explorando vulnerabilidades, sem necessariamente precisar de um arquivo hospedeiro ou interação do usuário. Embora worms possam transportar payloads como ransomware, eles não são definidos por criptografar arquivos e exigir resgate. O comportamento descrito no enunciado é

específico de ransomware, não de worm. Portanto, worm é uma classificação incorreta para o ataque em questão.

3) A — Implementar a solução correspondente: Macro VBA de documento Office: clássico — executa código ao abrir....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Malicious Code): Macro VBA de documento Office: clássico — executa código ao abrir.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: Sandbox: isola código suspeito num ambiente controlado....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Malicious Code): Sandbox: isola código suspeito num ambiente controlado.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) D — Implementar a solução correspondente: 'document that runs code when opened' = malicious macro....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Malicious Code): 'document that runs code when opened' = malicious macro.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: Cenário: 'funcionário abre planilha do email e o macro executa payload' = m....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Malicious Code): Cenário: 'funcionário abre planilha do email e o macro executa payload' = malicious macro — bloquear macros externas..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) D — Implementar a solução correspondente: Macro VBA de documento Office: clássico — executa código ao abrir....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Malicious Code): Macro VBA de documento Office: clássico — executa código ao abrir.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) D — Implementar a solução correspondente: Sandbox: isola código suspeito num ambiente controlado....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Malicious Code): Sandbox: isola código suspeito num ambiente controlado.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: 'document that runs code when opened' = malicious macro....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Malicious Code): 'document that runs code when opened' = malicious macro.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) A — Implementar a solução correspondente: Cenário: 'funcionário abre planilha do email e o macro executa payload' = m....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Malicious Code): Cenário: 'funcionário abre planilha do email e o macro executa payload' = malicious macro — bloquear macros externas..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.